

CCTV AMC & Service Management SaaS

Phase 1 Implementation Review & Readiness Assessment

Prepared for: Durwankur Technologies Pvt. Ltd.

Review type: Solution Architecture · Code · QA · Security Audit

Sources: SRS v1.2, TAD v1.0, full codebase

Date: 22 June 2026

Final verdict: **REQUIRES REWORK BEFORE SIGN-OFF**

0. Executive Summary

The team has delivered a **clean, well-layered architectural skeleton** with the right shape: FastAPI (async), SQLAlchemy 2.0 typed models, strict per-module model / schema / repository / service / router separation, a **TenantRepository** base enforcing tenant_id on every query, PostgreSQL RLS policies in the migration, correct GST intra/inter-state logic, an offline-sync mobile skeleton, and a CI pipeline. All 17 backend module routers are registered and the test suite (16 tests) passes.

However, **several requirements that the SRS and the project's own architectural constraints treat as mandatory exist only as scaffolding, not wired into the runtime:**

- **Audit log is never written** (SRS 4.21 + the 'every write hashes into audit_log' constraint). The model, table, RLS policy and compute_hash() exist, but no service or repository ever creates an AuditLog row.
- **The Notification Engine is never invoked** (SRS 4.15). AMC-renewal and SLA-breach tasks only logger.info(...).
- **Invoice / quotation / AMC numbers use in-memory counters** → duplicate, non-sequential numbers across workers & restarts — a **GST-compliance defect** (SRS 4.13).
- **Tenant isolation is tested only on SQLite, where RLS does not exist**, and _set_rls_context() swallows all exceptions — the headline security control is unverified.
- **RBAC is a single role string**, not the granular/custom-role model required by SRS 4.20.
- Whole functional areas are **missing or stubbed**: New Installation (4.5), Preventive Maintenance (4.9), Document & Warranty (4.17), Customer Portal (4.19), Platform Admin console UI, media/S3 upload, and most standard reports + Excel/PDF export (4.16).

FINAL VERDICT: REQUIRES REWORK BEFORE SIGN-OFF

Foundations are sound and recoverable, but the gap between 'scaffolded' and 'functional' is too large — and includes compliance- and security-critical items — to sign off.

1. Consolidated Phase 1 Deliverables

Per SRS 2, 'Phase 1' = full MVP scope (all 21 functional areas) minus explicit out-of-scope items (live NVR/DVR feeds, ERP replacement, self-service tenant signup, white-label mobile apps, online payment gateway).

#	Area (SRS §)	Key required capability
4.1	Tenant / Platform Mgmt	Onboard tenants, branding, plans, lifecycle, platform-level subscription invoicing, admin console
4.2	Lead Mgmt	Sources, pipeline, assignment, lost reasons, convert → customer + initial quotation
4.3	Customer Master	3 categories, multiple contacts w/ roles, interaction history, status tags, search/segment
4.4	Vendor Master	Profile, PO linkage, performance, payables, status
4.5	New Installation	Survey workflow, work order, job status, handover/OTP, auto-AMC + warranty on handover
4.6	Site & Asset	Sites+geo, asset register, DVR/NVR, warranty alerts, status, photos/docs
4.7	AMC Contracts	Terms, asset linkage, status, renewal reminders, history/version trail
4.8	Service Tickets	Categorize, unique #, status machine, SLA timers + breach escalation, audit trail
4.9	Preventive Maint.	Auto-generate PM schedule from AMC, reschedule/skip, reminders, completion tracking
4.10	Technician / Field	Profiles/skills, assignment, GPS check-in/out, attendance, work/parts/signature/OTP
4.11	Inventory	Stock, multi-warehouse + van stock, auto-deduct, low-stock + reorder/PO, ledger
4.12	Quotation	Itemized, status, digital approve/reject, convert → AMC/work order
4.13	Invoicing	GST-compliant + sequential #, recurring AMC, non-GST, partial/credit notes, PDF/email
4.14	Payments	Multi-mode, ageing, receipts, vendor payables, reminders, gateway hooks
4.15	Notifications	SMS/email/WhatsApp/in-app, DB templates per event, in-app center
4.16	Reporting	Role dashboards, standard report set, Excel/PDF export, filters
4.17	Document / Warranty	Doc store per customer/site/asset, warranty vs AMC tracking, expiry alerts
4.18	Mobile App	Assigned work, offline + sync, GPS/photo/sign/OTP/parts

#	Area (SRS §)	Key required capability
4.19	Customer Portal	Raise/track complaints, view/approve quotes, AMC status, download invoices, feedback
4.20	Roles & Permissions	Two-tier RBAC, granular module-level perms, custom roles, multi-branch restriction
4.21	Audit & Security	Tamper-evident audit log, 2FA/OTP, encryption at rest/transit, isolation tested, backups
NFR	§5	3s load, 200 concurrent, horizontal scale, RLS at all layers, 99.5% uptime, TLS1.2+, INR/GST

2. Requirement Traceability Matrix (RTM)

Legend: ✓ Yes ~ Partial ✗ No

Req	Description	Impl.	Evidence	Remarks
4.1	Tenant mgmt	~	models/tenant.py, api/v1/tenants.py	Plans/branding/status present. No tenant subscription invoicing, no usage-limit enforcement, no platform admin UI. Status enum missing CANCELLED.
4.2	Lead mgmt	~	services/lead.py	Pipeline + convert exist. Bug: conversion hardcodes category=COMMERCIAL (loses lead category); does NOT create the mandated initial quotation.
4.3	Customer master	~	models/customer.py	3 categories + sites OK. Only single contact_person; no multi-contact table; no commercial branch/signatory; status=bool only; no interaction history.
4.4	Vendor master	~	services/vendor.py	CRUD only. No PO linkage, no performance tracking, no payables.
4.5	New installation	✗	—	No installation/work-order/survey module. sales_order is generic, not survey→handover→OTP→auto-AMC flow.
4.6	Site & asset	~	models/asset.py	Register, warranty_expiry, status OK. Site lacks geo-coords; status enum missing UNDER_REPAIR; no photo/doc attach; no warranty alerts.
4.7	AMC contracts	~	services/amc.py, workers/tasks.py	Create/link assets/status OK. Renewal task only logs; no version trail; no Expiring-Soon auto-transition.
4.8	Service tickets	~	services/service_ticket.py	Ticket #, status, SLA due set. Breach only sets flag + logs — no escalation notification; no comments/attachments trail.
4.9	Preventive maint.	✗	preventive_visits_per_year stored only	No PM schedule generation, reschedule/skip, or reminders.
4.10	Technician / field	~	services/engineer_visit.py	GPS check-in/out + parts deduction good. No technician profile/skills/attendance; no geofence validation; OTP/signature not persisted.
4.11	Inventory	~	services/inventory.py	Stock + movements + low-stock OK. No multi-warehouse/van-stock; no reorder/PO workflow to vendors.
4.12	Quotation	~	services/quotation.py	Itemized + GST + status. No digital approve/reject; no convert-to-AMC/work-order; numbering bug.
4.13	Invoicing	~	services/invoice.py	GST CGST/SGST/IGST + credit note OK. _INV_SEQ in-memory → duplicate invoice numbers (GST non-compliant) . No PDF/email, no recurring AMC invoices.
4.14	Payments	~	services/payment.py	Multi-mode + ageing good. No receipts, no vendor payables, no reminders. Money handled as float.
4.15	Notifications	~	services/notification.py	Engine + DB templates + Celery dispatch exist, but no module ever calls .send() . WhatsApp/in-app are TODO comments.
4.16	Reporting	~	services/reports.py	Dashboard KPIs + SLA report only. Most standard reports missing; no Excel/PDF export; 'read replica' claimed but uses primary; KPI aggregation is a TODO.
4.17	Document / warranty	✗	—	No document model/storage; no S3 upload code (boto3 unused); no warranty alerts.
4.18	Mobile app	~	mobile/src/...	Login, ticket list, visit detail, offline queue, sync, location present. References POST /engineer-visits/media which does not exist → media/signature sync 404.
4.19	Customer portal	✗	—	Not implemented (no routes, no UI).
4.20	Roles & permissions	✗	models/user.py, core/deps.py	Two-tier + coarse require_roles only. No permissions/roles/user_roles tables, no granular perms, no custom roles, no multi-branch. Contradicts TAD 5.2.
4.21	Audit & security	✗	models/audit_log.py only	Audit log NEVER written. No 2FA/OTP, no encryption-at-rest, no password policy. RLS untested (SQLite tests). Backups absent.
NFR	Perf / scale	~	stateless API, pool config	Scale viable except in-memory sequence counters break statelessness. No rate-limit, caching, or replica routing.

Req	Description	Impl.	Evidence	Remarks
NFR	Security	~	JWT, bcrypt, RLS migration, CORS, gitleaks	TLS at Nginx; secrets externalized. But encryption-at-rest, RLS verification, audit, rate-limit all missing.
NFR	Localization	✓	GST logic, INR, Asia/Kolkata tz	Adequate for Phase 1.

3. Architecture Review

Strengths

- Clean layering (api → services → repositories → models), module-per-file consistency.
- TenantRepository consistently injects tenant_id on get/list/create across ~13 services — application-layer isolation is real.
- RLS policies created for all tenant-scoped tables with FORCE ROW LEVEL SECURITY (migration L406-416).
- Lazy engine init keeps Alembic clean; structlog, Prometheus, Sentry, health endpoint all wired.
- Secrets externalized; .env untracked; gitleaks in CI.

Concerns & Recommendations

1. **Audit mixin missing.** Add an audit hook in TenantRepository.create/save/delete capturing before/after + chaining compute_hash(), transactionally.
2. **In-memory sequences** violate statelessness and duplicate numbers. Use a persisted per-tenant document_sequences table with SELECT ... FOR UPDATE, or Postgres sequences.
3. **_set_rls_context() swallows exceptions and rolls back** (base.py L33-35). If SET LOCAL fails, RLS silently isn't applied. Fail loudly.
4. **Logging doesn't bind tenant_id** (only trace_id) — required for multi-tenant observability.
5. **Money as float** in service math against Numeric(12,2) columns — rounding risk on tax/totals. Use Decimal end-to-end.
6. **No rate limiting, Redis caching, or read-replica routing** despite TAD 13 / plan.
7. **make_crud(exclude_none=False) on create** writes explicit None for omitted optionals, overriding model defaults in some paths.

4. UI / UX Review (Web + Mobile)

- **Web:** 7 feature pages + dashboard, Ant Design shell, protected layout, Redux slices for auth/customers/tickets.
- **Missing UI** for Vendors, Assets/Sites, Inventory, Quotations, Sales Orders, Engineer Visits, Notifications, Reports, Users, and the Platform Admin console. A ComingSoon component exists but is not even routed.
- **No Customer Self-Service Portal** (4.19).
- **Weak auth gating:** ProtectedLayout checks only localStorage truthiness — no expiry/refresh handling, no role-based menu.
- Form validation / responsiveness / accessibility not demonstrable for missing modules.
- **Mobile:** solid technician skeleton (offline queue, NetInfo sync, location, last-write-wins) but depends on a backend media endpoint that does not exist; no conflict-flagging UI.

5. API & Backend Review

- **Design:** RESTful, versioned /api/v1, consistent bounded pagination, Pydantic v2 schemas, HTTPBearer auth. Good.
- **AuthZ:** require_roles(...) / require_platform_admin applied on write routes. Coarse but present.
- **Login bug** (services/auth.py L11): query not tenant-scoped, but unique index is (tenant_id, email). Duplicate cross-tenant email → MultipleResultsFound → 500 / login failure.
- **Refresh tokens not rotated/revocable** (plan promised rotation); no session denylist.
- **Missing endpoints:** media upload, quotation approve/reject, lead→quotation, customer-portal, tenant subscription invoices, document upload, report exports, technician profile.
- **Peripheral:** sales_orders is broad but not connected to the installation workflow it should support.

6. Database Review

- **Schema:** 20 tables, all tenant-scoped tables carry indexed tenant_id NOT NULL; audit_logs.chain_hash present; migration coherent and reversible.
- **RLS:** enabled + FORCE + policy on every tenant table — good design, but unverified at runtime (no Postgres-level test).
- **Indexing:** per-table tenant_id + composite unique ix_users_email_tenant. Recommend composite indexes on hot filters: (tenant_id, status) on tickets/invoices/AMC, (tenant_id, due_date) for ageing.
- **Integrity gaps:** enums stored as free String (no DB CHECK) — invalid statuses can persist. Money columns Numeric(12,2) but bypassed by float math.
- **Absent tables:** document_sequences, roles/permissions, documents, PM-schedule, installation/work-order — mirroring the functional gaps.

7. Quality Assessment

Area	Rating (1-10)	Comments
Requirement Coverage	4	~6 of 21 areas functionally complete; 3 absent; audit & notifications scaffolded-only.
Code Quality	7	Clean, consistent, typed; let down by in-memory counters, float money, swallowed exceptions.
Architecture	7	Right patterns; key cross-cutting concerns (audit, notify, sequences) not wired.
Security	3	RLS designed but untested + fails silently; no audit, 2FA, encryption-at-rest; login multi-tenant bug; no rate limit.
Scalability	5	Stateless intent good, but in-memory sequences + no caching/replica break it under load.
Maintainability	7	Modular; needs DB-enum constraints and shared audit/sequence utilities.
UI / UX	3	~half the modules + both admin and customer portals missing; weak auth gating.
Testing Readiness	3	16 tests green but 75% line coverage is router-inflated; core services 24-59% (notification 0%); RLS/isolation tested only on SQLite.

8. Gap Analysis

Critical (block sign-off)

1. **Audit logging not implemented** (4.21 + project constraint) — no AuditLog row ever written.
2. **Invoice/quotation/AMC numbering via in-memory counters** — duplicate numbers → GST non-compliance + statelessness break.
3. **RLS unverified & failure-silent** — isolation tested only on SQLite; `_set_rls_context` hides errors.
4. **Notification Engine never invoked** — 4.15 non-functional end-to-end.
5. **Login not tenant-scoped** — MultipleResultsFound on duplicate emails across tenants.
6. **RBAC granular permissions / custom roles absent** (4.20).

Major

7. New Installation workflow (4.5) — absent.
8. Preventive Maintenance scheduling (4.9) — absent.
9. Customer Self-Service Portal (4.19) — absent.
10. Document & Warranty mgmt + S3 media upload (4.17, 4.18) — absent; mobile media sync will 404.
11. Platform Admin console UI + tenant subscription invoicing (4.1) — absent.
12. Reporting: standard report set + Excel/PDF export + KPI aggregation (4.16) — mostly absent.
13. Multi-contact/customer status/interaction history (4.3); multi-warehouse + reorder/PO (4.11); quotation digital approval + conversion (4.12).

Minor

14. Lead→customer loses category & skips initial quotation.
15. Asset status missing UNDER_REPAIR; tenant status missing CANCELLED; no site geo-coords.
16. `tenant_id` not bound to log context; no rate limiting/caching/replica routing.
17. Money handled as float.

Technical Debt

- Enums stored as unconstrained strings (no DB CHECK).
- Repeated `_next*_number` logic should be one shared, persisted utility.
- `make_crud(exclude_none=False)` can clobber defaults.
- Refresh tokens non-rotating / non-revocable.

9. Risk Assessment

Risk	Likelihood	Impact	Exposure
Cross-tenant data leak (RLS silently off / untested)	Medium	Critical	High
Duplicate GST invoice numbers (legal/compliance)	High	High	High
No audit trail (compliance/forensics, 4.21)	High (certain today)	High	High
Login failure on duplicate cross-tenant email	Medium	High	Med
Notifications silently never sent (missed renewals/SLA)	High	Medium	Med
Money rounding errors (float)	Medium	Medium	Med
Mobile media sync 404 (loss of photos/signatures)	High	Medium	Med

10. Final Phase 1 Readiness Assessment

REQUIRES REWORK BEFORE SIGN-OFF

Justification. The architecture is genuinely good and the path to done is clear — but Phase 1 cannot be signed off while (a) the platform's headline security control (tenant RLS) is unverified and fails silently, (b) two explicitly-mandated, compliance-bearing capabilities — tamper-evident audit logging and sequential GST invoice numbering — are non-functional, (c) the Notification Engine produces nothing end-to-end, and (d) three whole functional areas (New Installation, Preventive Maintenance, Customer Portal) plus the Platform Admin UI are absent. '16 tests pass' is misleading: coverage is router-inflated and the isolation test runs on a database (SQLite) that has no RLS.

Recommended path to sign-off (minimum bar)

1. Wire **audit logging** into the repository write path with hash chaining (transactional).
2. Replace **in-memory counters** with a persisted per-tenant sequence; add a uniqueness test.
3. Add a real **Postgres-backed RLS/isolation test** (two tenants, non-superuser role); make `_set_rls_context` fail loudly.
4. **Tenant-scope login**; add refresh-token rotation/revocation.
5. **Invoke NotificationService.send()** from AMC-renewal, SLA-breach, ticket-assignment, payment-due flows.
6. Implement **granular RBAC** (roles/permissions tables) per 4.20.
7. Build the missing core modules: **New Installation (4.5)**, **PM scheduling (4.9)**, **media/S3 upload + mobile media endpoint, document/warranty (4.17)**, **Platform Admin console**.
8. Raise core-service **test coverage to ≥80%** (notification, payment, engineer_visit, amc, reports first).
9. Switch money math to **Decimal**; add DB CHECK constraints on status enums; bind `tenant_id` to logs.

Deliverables mapping — RTM: 2 · Feature Coverage: 2 + 8 · Architecture Review: 3, 5, 6 · Gap Analysis: 8 · Risk Assessment: 9 · Final Readiness: 10.